

Threat model

Assets

Identity tokens and roles; phone/email/address/location; KYC documents; caste/community selections; booking/travel schedules; chat/voice; payment/refund/payout records; safety/emergency records; provider supply; analytics/device identifiers; cloud/API credentials; AI/maps quotas.

Boundaries and attacker classes

```
flowchart LR
    A["Anonymous bot"] --> E["CloudFront/WAF"]
    T["Authenticated malicious tenant"] --> API["Express API"]
    I["Malicious/compromised admin"] --> ADM["Admin APIs"]
    S["Repo/CI compromise"] --> SEC["Secrets + deployment"]
    E --> API
    O["Direct-origin caller"] --> ALB["Public ALB"] --> API
    API --> DATA["Postgres / Redis / DynamoDB / S3"]
    API --> V["Payment / AI / maps / messaging vendors"]
```

Abuse cases

Threat	Existing control	Gap	Priority response
Credential theft from repo/history	AWS Secrets Manager exists in runtime design	Real values tracked	Rotate/purge/scan
Tenant reads/deletes victim documents	Auth required, private S3	No object ownership on read/delete/list	BOLA fix/tests
Fake verified provider	KYC abstraction/readiness gates	Provider auto-approves	Fail closed/manual review
WAF/rate bypass	CloudFront WAF	Public HTTP ALB	Restrict/authenticate origin
WS cross-user subscription	Some token parsing	Anonymous/arbitrary channels	Authz per subscription
Coupon/payment/refund races	DB uniqueness, transactions, idempotency tests	Full live reconciliation missing	Gateway sandbox/E2E/reconciliation
Denial of wallet	Endpoint rate limits/caches	Limits IP-keyed; AI/voice/Maps costly	User quotas, budgets, circuit breakers
PII leakage in logs	Structured logger/redaction in some paths	Speech partials, IDs, query tokens	Data-classification/redaction tests
Discriminatory access	Product allow-list gate	Legal/ethical harm is implemented feature	Disable and counsel review
Support abandonment	Contact UI	Fake delivery/no case record	Real ticketing and audit

Highest-impact attack paths

1. Repository access -> extract still-valid service account/payment/database secrets -> cloud/data/cost compromise.
2. Ordinary account -> victim object key -> presign/read/delete/list private S3 content.
3. Provider account -> mock KYC -> "verified" listing -> physical/financial fraud.
4. Direct ALB DNS -> bypass CloudFront WAF/TLS policy -> abuse expensive/open API paths.
5. WS client -> subscribe arbitrary channel -> receive another user's events as publisher coverage expands.

Findings

ID	Domain	Title	Severity	Confidence	Evidence	User/business impact	Recommended correction	Effort	Owner	Release blocker	Status
TM-001	Threat model	Tenant isolation fails at object storage boundary	High	Confirmed	SEC-002	Private-data loss	Central resource authorization	Medium	Backend/CISO	yes	Open
TM-002	Threat model	Trust badge can be forged through designed flow	High	Confirmed	SEC-003	User safety/reputation	Real/manual verification	Medium	Trust	yes	Open
TM-003	Threat model	Cost-amplifying APIs lack verified subject quotas	High	High confidence	limiter order + PDF AI cost	Unexpected cloud bill	Quotas/budgets/kill switches	Medium	SRE/CFO	yes	Open
TM-004	Threat model	Insider/admin abuse controls untested	Medium	Requires validation	Admin audit exists; no dual-control evidence	Fraud/data alteration	MFA, JIT admin, dual control, review	High	CISO	before paid	Open